

Deployment Guide

ECITY — Mobile Shop Management Web App

Version 1.2 · 2026

Buying the server, deploying, backups and the runbook

Companion documents: PRD, Module Breakdown, Engineering Design, Deployment Guide, Database Guide

1. What You Are Buying, and From Whom

You need one thing: a **small Linux server on the internet**, rented by the month. That is it. Everything else — the app, the database, the web server — runs inside that one machine as Docker containers.

That kind of rented machine is called a **VPS** (Virtual Private Server) or a "cloud instance". Several companies sell them, and they are direct competitors — you buy from **one** of them, not through AWS.

Revised September 2026. This section originally recommended Hetzner Singapore at ≈₹400–600. Two things have since made that advice wrong, and both were found the hard way when the server was actually being bought:

>

1. **Hetzner's CX line is EU-only.** Singapore never had CX22 or CX23 — it sells the AMD CPX line instead. The old instruction to pick "CX22 in Singapore" described a machine that does not exist. 2. **Hetzner raised cloud prices sharply on 15 June 2026.** CX22 went from €7.99 to **€19.49/month** — a 144% rise. Comparable CPX increases were around 170–190%.

>

The result is that Hetzner is no longer the cheap option. It is now the most expensive of the realistic choices *and* the furthest away.

1.1 What things actually cost now

Verify each of these yourself before paying — as the box above shows, they move.

Provider	Nearest region	Specs	Per month	Latency from Kerala
Vultr (recommended)	Mumbai	1 vCPU / 2 GB / 55 GB / 2 TB	\$10 ≈ ₹880 + 18% GST	~20–30 ms
DigitalOcean	Bangalore	1 vCPU / 2 GB / 50 GB / 2 TB	\$12 ≈ ₹1,060 + 18% GST	~20–30 ms
AWS Lightsail	Mumbai	2 vCPU / 2 GB / 60 GB / 3 TB	\$12 ≈ ₹1,060 + 18% GST	~20–30 ms
Hetzner	Helsinki (EU)	2 vCPU / 4 GB / 40 GB	€19.49 ≈ ₹2,000, no GST	~150 ms

Recommendation: an India region, on Vultr Mumbai or DigitalOcean Bangalore. It is now cheaper than Hetzner, three times closer, and it keeps the shop's sales records inside India — which is one fewer thing to explain to a CA. Pick Vultr on price, DigitalOcean if you would rather have the friendlier control panel and much better beginner documentation; the difference is about ₹200 a month.

Nothing in this guide is Hetzner-specific. Every provider gives you the same thing: an Ubuntu machine and an IP address. \$3 onwards applies unchanged.

1.2 You do not need production yet

Right now you need **staging** — somewhere the Alpha can be shown. Production does not exist until go-live (M14). So buy the smaller machine now and size production properly later, when you know the real load:

- **Staging today:** the smallest 1 GB instance (Vultr \$5–6 ≈ ₹500 + GST). The server never compiles anything — it pulls a pre-built image — so 1 GB is enough for Postgres, the app and Caddy with room to spare.
- **Production at go-live:** 2 GB. Revisit then; a year of prices moving means any number written here today will be wrong by then.

1.3 Total monthly cost

For **staging only**, which is where the project is now:

Item	₹ / month
1 GB VPS in an India region	~₹500 + GST
Provider automated backups (+20%)	~₹100
Cloudflare R2 — file storage + off-site backups (free tier, 10 GB)	₹0
Resend — transactional email (free tier, 3,000/month)	₹0
Sentry — error tracking (free tier)	₹0
Domain name (.in, ~₹800/year)	~₹70
Total	≈ ₹700–800

Add roughly ₹500–600 more when production comes up on a 2 GB instance alongside it. The original ₹550–750 estimate for a *production* box no longer holds: the honest figure today is ₹1,200–1,400 **all-in** once both are running. That is the market moving, not a change of plan — and it is still an order of magnitude below what a managed platform would charge.

1.4 A 2 GB box needs Postgres told to be modest

The defaults assume a machine with far more memory. On a 1–2 GB instance, add this to the `db` service in `docker-compose.prod.yml`:

```
command: >
  postgres
  -c shared_buffers=256MB
  -c effective_cache_size=768MB
  -c work_mem=8MB
  -c maintenance_work_mem=64MB
  -c max_connections=50
```

Without it Postgres will happily reserve more than the box has and the kernel will kill something — usually the app, at the worst possible moment.

2. Day One: The Shopping List

Do these four things before touching any code. Budget about an hour.

2.1 Create an account with your chosen provider (see §1.1 — Vultr Mumbai or DigitalOcean Bangalore). You will need a credit/debit card. New accounts are sometimes asked for an identity document before the first server can be created; this is normal and usually clears within a few hours. Start this first so the wait does not block you.

If you already opened a Hetzner account: keep it, it costs nothing dormant. Their Singapore region does not sell the machine this guide assumed, and their EU prices tripled in June 2026 — see §1.1.

2.2 Buy a domain name. Any registrar works — Namecheap, Cloudflare Registrar, or an Indian registrar like BigRock. A .in domain runs about ₹800/year. You will point it at the server in §5.

2.3 Create a Cloudflare account (free) — cloudflare.com. You need it for two things: free DNS management, and **R2** object storage for backups and uploaded bill photos. R2's free tier is 10 GB of storage with zero egress fees, which will cover this shop for a long time.

2.4 Create a GitHub account and a private repository for the code, if you have not already. Deployments will run from here.

3. Creating the Server

3.1 Make an SSH key first

An SSH key is how you log in to the server — safer than a password, and you never type it. On your Mac, in Terminal:

```
ssh-keygen -t ed25519 -C "ecity-server"
# press Enter to accept the default path
# set a passphrase when asked, and remember it

cat ~/.ssh/id_ed25519.pub      # this prints the PUBLIC key - copy it
```

The `.pub` file is the **public** key and is safe to paste anywhere. The file without `.pub` is your **private** key — it never leaves your Mac and is never shared, committed or emailed.

3.2 Create the server

In your provider's console, create a project called `ecity` and add a server. The labels differ slightly between providers; the choices are the same:

Setting	Choose
Location	Mumbai or Bangalore — whichever your provider offers
Image	Ubuntu 24.04 LTS
Type	Shared/Regular vCPU, 1 GB for staging or 2 GB for production (§1.2)
Networking	IPv4 + IPv6 (both on)
SSH keys	Add the public key you just copied
Volumes / Placement	skip
Backups	Enable (+20% — do not skip this)
Firewall	create one, see below
Name	<code>ecity-prod</code>

Firewall rules (inbound; everything else denied):

Port	Protocol	Source	Why
22	TCP	your IP, or Any	SSH login
80	TCP	Any	HTTP (redirects to HTTPS)
443	TCP	Any	HTTPS

Postgres port 5432 is **never** opened to the internet. The app reaches the database over Docker's internal network.

Click Create. After about 30 seconds you get an IP address like `5.223.x.x`. Write it down.

3.3 First login and hardening

```
ssh root@YOUR_SERVER_IP

# 1. create a normal user for day-to-day work
adduser ecity
usermod -aG sudo ecity
rsync --archive --chown=ecity:ecity ~/.ssh /home/ecity

# 2. updates and basic protection
apt update && apt upgrade -y
apt install -y ufw fail2ban unattended-upgrades
dpkg-reconfigure --priority=low unattended-upgrades

# 3. host firewall (second layer behind the provider's own)
ufw allow OpenSSH
ufw allow 80/tcp
ufw allow 443/tcp
ufw --force enable

# 4. turn off password logins entirely
sed -i 's/^#*PermitRootLogin.*/PermitRootLogin prohibit-password/' \
/etc/ssh/sshd_config
sed -i 's/^#*PasswordAuthentication.*/PasswordAuthentication no/' \
/etc/ssh/sshd_config
systemctl restart ssh
```

Now open a **second** terminal and confirm `ssh ecity@YOUR_SERVER_IP` works before closing the first one. If you lock yourself out, your provider's web console gets you back in — but check first anyway.

3.4 Install Docker

```
curl -fsSL https://get.docker.com | sh
usermod -aG docker ecity
# log out and back in as ecity, then verify:
docker run --rm hello-world
```

4. The Application Stack

Everything lives in `/home/ecity/app` on the server. Four containers:

```
Internet :443
|
[caddy]    TLS certificates, automatic and free
|
[app]      Next.js (long-running Node process, port 3000)
|
[db]       PostgreSQL 16          [worker] pg-boss jobs
```

Because the app is a **long-running process**, not serverless functions, there is no cold start and no database connection-pool problem. One small pool of ~10 connections is opened once and reused.

4.1 docker-compose.yml

```
services:
  db:
    image: postgres:16-alpine
    restart: unless-stopped
    environment:
      POSTGRES_USER: ecity
      POSTGRES_PASSWORD: ${POSTGRES_PASSWORD}
      POSTGRES_DB: ecity
    volumes:
      - db_data:/var/lib/postgresql/data
    healthcheck:
      test: ["CMD-SHELL", "pg_isready -U ecity"]
      interval: 10s
      retries: 5

  app:
    image: ghcr.io/YOURNAME/ecity:latest
    restart: unless-stopped
    env_file: .env
    depends_on:
      db: { condition: service_healthy }
    expose: ["3000"]

  worker:
    image: ghcr.io/YOURNAME/ecity:latest
    command: ["node", "dist/jobs/worker.js"]
    restart: unless-stopped
    env_file: .env
    depends_on:
      db: { condition: service_healthy }

  caddy:
    image: caddy:2-alpine
    restart: unless-stopped
    ports: ["80:80", "443:443"]
    volumes:
      - ./Caddyfile:/etc/caddy/Caddyfile:ro
      - caddy_data:/data
      - caddy_config:/config
    depends_on: [app]

volumes:
  db_data:
  caddy_data:
  caddy_config:
```

4.2 Caddyfile

Two lines gets you HTTPS with a free certificate that renews itself:

```
app.yourshop.in {
  encode gzip
  reverse_proxy app:3000
}
```

Caddy places no limit on request body size, which is what the go-live import needs — a file goes up in one request, and a spreadsheet is sent as bytes, so a shop's stock list can be several megabytes. If you ever add a [request_body max_size](#) here, keep it above 15 MB or the import will fail at the one moment it matters. (Nginx is the other way round: its default of 1 MB would need raising.)

4.3 .env on the server

Create it with `nano .env`, then `chmod 600 .env`. **This file is never committed to git.**

```
POSTGRES_PASSWORD=<long random string>
DATABASE_URL=postgres://ecity:<same password>@db:5432/ecity
```

```

AUTH_SECRET=<openssl rand -base64 32>
AUTH_URL=https://app.yourshop.in
R2_ACCOUNT_ID=...
R2_ACCESS_KEY_ID=...
R2_SECRET_ACCESS_KEY=...
R2_BUCKET=ecity-uploads
RESEND_API_KEY=...
SENTRY_DSN=...
NODE_ENV=production

```

Generate secrets with `openssl rand -base64 32`. Never reuse the same value twice.

4.4 Dockerfile (in the repo)

Next.js needs `output: 'standalone'` in `next.config.ts` for this to work — set that first.

```

FROM node:22-alpine AS deps
WORKDIR /app
COPY package*.json ./
RUN npm ci

FROM node:22-alpine AS build
WORKDIR /app
COPY --from=deps /app/node_modules ./node_modules
COPY . .
RUN npm run build

FROM node:22-alpine AS run
WORKDIR /app
ENV NODE_ENV=production
COPY --from=build /app/.next/standalone ./
COPY --from=build /app/.next/static ./next/static
COPY --from=build /app/public ./public
EXPOSE 3000
CMD ["node", "server.js"]

```

5. Domain and DNS

1. In Cloudflare, add your domain and change the nameservers at your registrar to the two Cloudflare gives you. Propagation takes minutes to a few hours.
2. Add one DNS record:

Type	Name	Value	Proxy
A	app	your server IP	DNS only (grey cloud)

Keep the proxy **off** at first so Caddy can obtain its certificate. You can turn Cloudflare's orange-cloud proxy on afterwards if you want, but it is not needed.

3. Once DNS resolves, `docker compose up -d` and Caddy fetches a Let's Encrypt certificate automatically. <https://app.yourshop.in> is live.

6. Deploying

Build the image in GitHub Actions, push it to GitHub's container registry, then have the server pull it. The server never compiles anything — it only downloads and restarts, so a deploy takes seconds and a bad build never reaches production.

6.1 The workflow

The real file is `.github/workflows/deploy.yml` in the repository — read that rather than a copy here, since a copy in a document goes stale. What it does, and *why* each part is the way it is:

It refuses to deploy code that fails. The deploy job declares `needs: [check]`, and `check` calls the whole CI workflow. A push whose tests, types or lint fail never reaches the server. An earlier version of this file had `needs: []`, which meant a red build shipped anyway — worse than no automation at all, because it looks safe.

Two images are built, not one.

Tag	What it is	Why
<code>:latest, :<sha></code>	the Next.js standalone server	what serves customers
<code>:migrate</code>	node_modules + <code>drizzle/</code> + the db scripts	runs migrations, then exits

The runtime image is a `.next/standalone` bundle. It has **no `drizzle-kit` and no `tsx`** — those are dev dependencies, and shipping a toolchain into the container that faces the internet is not worth it. So migrations get their own small image which is run once per deploy and thrown away. (The original workflow tried to run `drizzle-kit` from the app image with `|| true` on the end. It could never have worked, and the `|| true` would have hidden that forever while the app served traffic against an un-migrated schema.)

The order matters, and nothing is allowed to fail quietly:

```
docker compose pull
docker compose run --rm migrate                # schema first
docker compose run --rm migrate npm run db:sync-roles # then permissions
docker compose up -d --wait app caddy          # then release
curl /api/health                               # then prove it
```

`script_stops: true` plus `set -euo pipefail` means any step failing stops the deploy with a red build, instead of carrying on to start a broken release.

Why `db:sync-roles` is a deploy step. A module that adds a permission adds it to `SYSTEM_ROLES` in the code. Roles already in the database keep whatever they were seeded with, so the new screen returns 403 for *everyone* — including the owner — until the roles are re-synced. M5 hit exactly this: `Customer dues` was built, deployed, and invisible. The sync is idempotent, touches only roles marked `is_system`, and leaves anything the shop created itself alone.

The health check is not optional. Ten one-second tries against `/api/health`; if none succeed the job prints the last 50 lines of the app log and fails. Without it a deploy that crash-loops reports success.

Add `SSH_HOST` (the server IP) and `SSH_KEY` (your **private** key) as GitHub repository secrets under Settings → Secrets and variables → Actions.

6.2 Standing up staging (M5)

There is a step-by-step walkthrough for Vultr Mumbai at `deploy/staging/README.md`, with the compose file, Caddyfile and `.env` template beside it, already filled in for this repository. Follow that. The summary below is what it does and why.

Everything above is written and committed. What is left needs **your provider account and card**, so it cannot be automated from here. Roughly 40 minutes:

1. **Create the server.** Follow §3 exactly, but name it `ecity-staging`. A The smallest 1 GB instance in an India region is enough for staging (§1.2) — about ₹500/month. Note the IP.
2. **Harden it.** §3.1 as written — normal user, firewall, no password logins.
3. **Put the stack on it.**

```
ssh ecity@<ip>
mkdir -p ~/app && cd ~/app
# copy docker-compose.prod.yml, Caddyfile and .env from the repo
# in docker-compose.prod.yml replace YOURNAME with your GitHub username
```

4. **Write .env** with a *staging* `DATABASE_URL`, a freshly generated `AUTH_SECRET` (`openssl rand -base64 32`), and `POSTGRES_PASSWORD`. Never reuse production values.
5. **Give it a hostname.** The session cookie is *Secure* in production mode, so a bare `http://<ip>` shows the login page and then silently refuses to log anyone in — HTTPS is not optional. Staging avoids buying a domain by using `<ip>.sslip.io`, a free public DNS service that resolves any such name to that IP; Caddy then gets a real certificate for it automatically. Swap in a proper domain whenever you buy one.

Use the **IPv4** address. `curl ifconfig.me` returns IPv6 on a dual-stack server, and an IPv6 address contains colons, which are illegal in a domain name — Let's Encrypt refuses to issue, and the site then hangs with nothing obvious in the browser. Force it with `curl -s -4 ifconfig.me`.

6. **Give GitHub the keys.** Repository → Settings → Secrets → Actions: `SSH_HOST` = the IP, `SSH_KEY` = the private key that matches the one you put on the server.
7. **Let the registry pull.** On the server, `docker login ghcr.io -u <github-username>` with a personal access token that has `read:packages`.
8. **Push to main.** The workflow builds, migrates, syncs roles, releases and health-checks. Watch it under the Actions tab.
9. **Seed it once**, so there is something to log in with:

```
docker compose run --rm migrate npm run db:seed
```

Staging only. The seed creates accounts with known passwords.

Verify it worked: open `https://staging.yourdomain.com`, sign in, and walk the M0 section of the Manual Test Checklist. If the health check passed but the site does not load, the problem is DNS or Caddy, not the app — check `docker compose logs caddy`.

6.3 Two rules about migrations

1. **Always take a backup before a migration that drops or renames anything.** `./backup.sh` first, every time.
2. **Test every migration on staging before production.** Staging can be a second, smaller instance (~₹500) or just a second Docker stack on the same box using a different database name and port. Cheap either way, and it is what stops a bad migration reaching real sales data.

7. Backups — The Part You Cannot Skip

You are running your own database now, so backups are entirely your responsibility. This is the only real thing you gave up by not paying for managed hosting. Three layers:

Layer	What it protects against	Frequency
Provider snapshots	Server dies, disk corrupts	Daily, automatic
<code>pg_dump</code> to Cloudflare R2	Bad migration, wrong DELETE, provider outage	Nightly, off-site
Restore drill	Backups that were never actually valid	Monthly, by hand

7.1 backup.sh

```
#!/usr/bin/env bash
set -euo pipefail
cd /home/ecity/app
STAMP=$(date +%F-%H%M)
OUT=/var/backups/ecity
mkdir -p "$OUT"

# -Z 0 = no Postgres compression, so restic can deduplicate
# between snapshots. Without it every nightly backup stores a
# full fresh copy and the R2 free tier fills up fast.
docker compose exec -T db \
  pg_dump -U ecity -Fc -Z 0 ecity > "$OUT/db-$STAMP.dump"

export RESTIC_REPOSITORY="s3:https://$R2_ACCOUNT_ID.r2.cloudflarestorage.com/ecity-backups"
export AWS_ACCESS_KEY_ID="$R2_ACCESS_KEY_ID"
export AWS_SECRET_ACCESS_KEY="$R2_SECRET_ACCESS_KEY"
export RESTIC_PASSWORD="$RESTIC_PASSWORD"

restic backup "$OUT"
restic forget --keep-daily 7 --keep-weekly 4 --keep-monthly 6 --prune
find "$OUT" -name 'db-*.dump' -mtime +3 -delete
```

With `-Z 0` and the retention below, seventeen retained snapshots deduplicate down to roughly the size of one or two — which is what keeps the whole backup history inside Cloudflare R2's free 10 GB.

Install with `apt install -y restic`, initialise once with `restic init`, then `chmod +x backup.sh` and schedule it — `crontab -e`:

```
# every four hours, so a crash costs at most one quarter of a trading day
30 */4 * * * /home/ecity/app/backup.sh >> /var/log/ecity-backup.log 2>&1
```

A nightly-only schedule means a disk failure at 8 PM loses **everything entered that day** across every branch. Four-hourly costs nothing extra and cuts the worst case to about four hours. For true point-in-time recovery — restoring to any moment, including just before a bad migration — add WAL archiving with `pgBackRest` or `wal-g` shipping to the same R2 bucket. That is roughly half a day of setup in M13 and brings the worst case down to about five minutes.

7.2 The monthly restore drill

Put a recurring reminder in your calendar. It takes ten minutes.

```
# 1. pull the latest backup down
restic restore latest --target /tmp/restore

# 2. load it into a scratch database
docker compose exec -T db createdb -U ecity ecity_drill
docker compose exec -T db pg_restore -U ecity -d ecity_drill \
  /tmp/restore/var/backups/ecity/db-<stamp>.dump

# 3. confirm it is real data, not an empty shell
docker compose exec -T db psql -U ecity -d ecity_drill \
  -c "select count(*) from sale; select count(*) from device_unit;"

# 4. clean up and note how long the whole thing took
docker compose exec -T db dropdb -U ecity ecity_drill
```

If the counts look right, your backups work. If you have never done this, **you do not have backups** — you have files you hope are backups.

8. Monitoring

What	Tool	Cost
Application errors	Sentry (free Developer tier)	₹0
Site down alert	UptimeRobot, 5-minute checks to email/SMS	₹0
Disk full	<code>df -h</code> in a weekly cron that emails if above 80%	₹0
Backup failed	Have <code>backup.sh</code> email or Sentry-alert on non-zero exit	₹0

Disk filling up is the single most common way a small VPS falls over. Old Docker images are usually the cause — `docker image prune -f` runs on every deploy in the workflow above, which handles it.

8b. Upgrading the server to a bigger plan

Do this **after the shop closes**. Not for the reboot — for the twenty minutes between taking the snapshot and switching over, during which anything billed would be written to the old machine and then thrown away. Closing time removes that risk completely.

On Lightsail there is no in-place resize. You snapshot, create a larger instance from the snapshot, and move the static IP across. DigitalOcean and Vultr can resize a running instance in place; Lightsail cannot, and it will not let you go back *down* to a smaller plan afterwards. Attach a static IP on day one, or the new instance comes up on a different address and DNS breaks.

The snapshot is the whole disk — Docker, the compose file, `.env`, the Caddy config and the database volume. Nothing is reinstalled and no deploy is needed; the application does not know it moved.

1. Record what should be there, and take a dump as a fallback

```
cd ~/app
docker compose exec -T db pg_dump -U ecity -Fc ecity > ~/pre-upgrade.dump
docker compose exec -T db psql -U ecity -d ecity -c \
    "select (select count(*) from sale) as sales,
           (select count(*) from device_unit) as devices,
           (select count(*) from customer_ledger_entry) as ledger;"
```

Write those three numbers down.

2. Stop everything, so the snapshot catches a closed database

```
docker compose down
```

A snapshot of a *running* instance is crash-consistent — the equivalent of pulling the power cord. Postgres replays its write-ahead log and usually recovers, but "usually" is the wrong standard for a sales ledger. Stopped, it flushes and closes properly.

3. Snapshot, create the larger instance, move the static IP

All three in the provider console.

4. Start it and check the numbers match

```
cd ~/app && docker compose up -d
docker compose exec -T db psql -U ecity -d ecity -c \
    "select (select count(*) from sale) as sales,
           (select count(*) from device_unit) as devices,
           (select count(*) from customer_ledger_entry) as ledger;"
curl -s https://YOUR_HOST/api/health
```

The three counts must match step 1 **exactly**, and health must report `"schema":"current"`.

5. Only then delete the old instance

Until you do, you have two ways back: the old machine, still intact, and `pre-upgrade.dump`. Keep both until the shop has traded a full day on the new one.

9. Runbook

Common operations, for when you need them and cannot remember.

```
# where everything lives
cd /home/ecity/app

# see what is running / logs
docker compose ps
docker compose logs -f app
docker compose logs --tail=200 worker

# restart one service
docker compose restart app

# deploy by hand (normally GitHub Actions does this)
docker compose pull && docker compose up -d

# roll back to the previous image
docker compose pull ghcr.io/YOURNAME/ecity:<previous-sha>
# edit docker-compose.yml to that tag, then:
docker compose up -d

# open a database shell
docker compose exec db psql -U ecity ecity

# take a backup right now
./backup.sh

# disk and memory
df -h && free -m && docker system df
```

Resizing the server (when 10 branches actually arrive): provider console → Server → Resize → the next tier up (4 vCPU / 8 GB). It reboots once, takes about a minute, and nothing else changes. You can scale up freely; scaling disk down is not possible on any of these providers, so do not over-provision the disk early.

10. Go-Live Checklist

- [] Provider account verified, instance running in an India region, snapshots enabled
- [] Provider firewall: only 22, 80, 443 inbound. Port 5432 closed
- [] SSH key login working; password login disabled; `ufw` enabled
- [] Domain pointing at the server; HTTPS live with a valid certificate
- [] `.env` present, `chmod 600`, and `not` in git
- [] All secrets freshly generated; none reused from development
- [] GitHub Actions deploys on push to `main`; tests gate the deploy
- [] Staging environment exists and migrations are tested there first

- [] `backup.sh` scheduled nightly and confirmed writing to R2
- [] **A restore drill completed successfully and timed at least once**
- [] Sentry receiving errors; UptimeRobot alerting to a phone
- [] Opening balances loaded (PRD FR-34)
- [] Two-week parallel run with paper records agreed with the shop

11. Things That Will Bite You

Mistake	What happens	Prevention
Never testing a restore	You discover the backups were empty on the day you need them	The monthly drill in §7.2
Exposing Postgres port 5432	The database is found and attacked within hours	Never publish port 5432; Docker's internal network only
Secrets committed to git	Credentials leak permanently, even after deletion	<code>.env</code> in <code>.gitignore</code> ; GitHub secrets for CI
Running migrations straight on production	One bad migration, no way back	Staging first, backup immediately before
Disk quietly filling up	Postgres stops accepting writes; the shop stops billing	<code>docker image prune</code> on deploy; weekly disk check
Editing files on the server by hand	The next deploy silently overwrites your fix	All changes go through git and CI, always
Only one person holds the SSH key	Nobody can reach the server if that laptop dies	Second key stored securely offline, or provider console access